

VIETNAM NATIONAL UNIVERSITY, HO CHI MINH CITY
UNIVERSITY OF SCIENCE
FACULTY OF INFORMATION TECHNOLOGY



Báo cáo đồ án 2

**Topic: Xây dựng Ứng dụng Web Serverless với Kiến trúc
bảo mật & Tối ưu chi phí**

Course: Nhập môn điện toán đám mây

Prepared by

Nguyễn Minh Tú 23120101

Nguyễn Xuân Duy 23120121

Nguyễn Minh Hiếu 23120124

Ngày 7 tháng 6 năm 2026

Mục lục

I	Giới thiệu	2
1	Phạm vi ứng dụng	2
2	Tóm tắt triển khai	2
3	Thông tin endpoint	3
II	Kiến trúc hệ thống	4
1	Sơ đồ kiến trúc	4
2	Luồng request	5
3	Tự mở rộng serverless	5
4	CDN và Origin Access Control	6
5	VPC Endpoint	6
III	Kết quả và bằng chứng	7
1	Bằng chứng bảo mật frontend	7
2	Bằng chứng Cognito và API security	9
3	Bằng chứng networking	12
4	Bằng chứng IAM	15
5	Giám sát	17
6	Chi phí	19
IV	Đánh giá	20
1	Bảng đánh giá	20
2	Phân chia công việc	21
A	Phụ lục	22

I Giới thiệu

1 Phạm vi ứng dụng

Ứng dụng Task Manager hỗ trợ các chức năng chính sau:

- Đăng ký và đăng nhập người dùng thông qua Amazon Cognito.
- Tạo, xem, cập nhật và xóa công việc.
- Lưu trữ dữ liệu công việc bền vững trong Amazon DynamoDB.
- Chỉ cho phép người dùng đã xác thực gọi các API `/tasks`.

2 Tóm tắt triển khai

Các điểm triển khai chính của hệ thống:

- Frontend được lưu trong S3 bucket riêng tư và chỉ được phục vụ qua CloudFront.
- CloudFront sử dụng Origin Access Control (OAC) để đọc object từ S3.
- Backend sử dụng API Gateway REST API stage `prod` và bốn Lambda function riêng biệt.
- Runtime của Lambda là Node.js 20.x.
- Lambda được đặt trong private subnet của custom VPC `TaskManagerVPC`.
- Lambda truy cập DynamoDB thông qua DynamoDB Gateway VPC Endpoint.
- API được bảo vệ bằng Cognito Authorizer.
- IAM được cấu hình theo nguyên tắc least privilege với bốn role riêng cho bốn Lambda function.
- CloudWatch Dashboard, CloudWatch Alarms, SNS và AWS Budget được cấu hình để giám sát và kiểm soát chi phí.

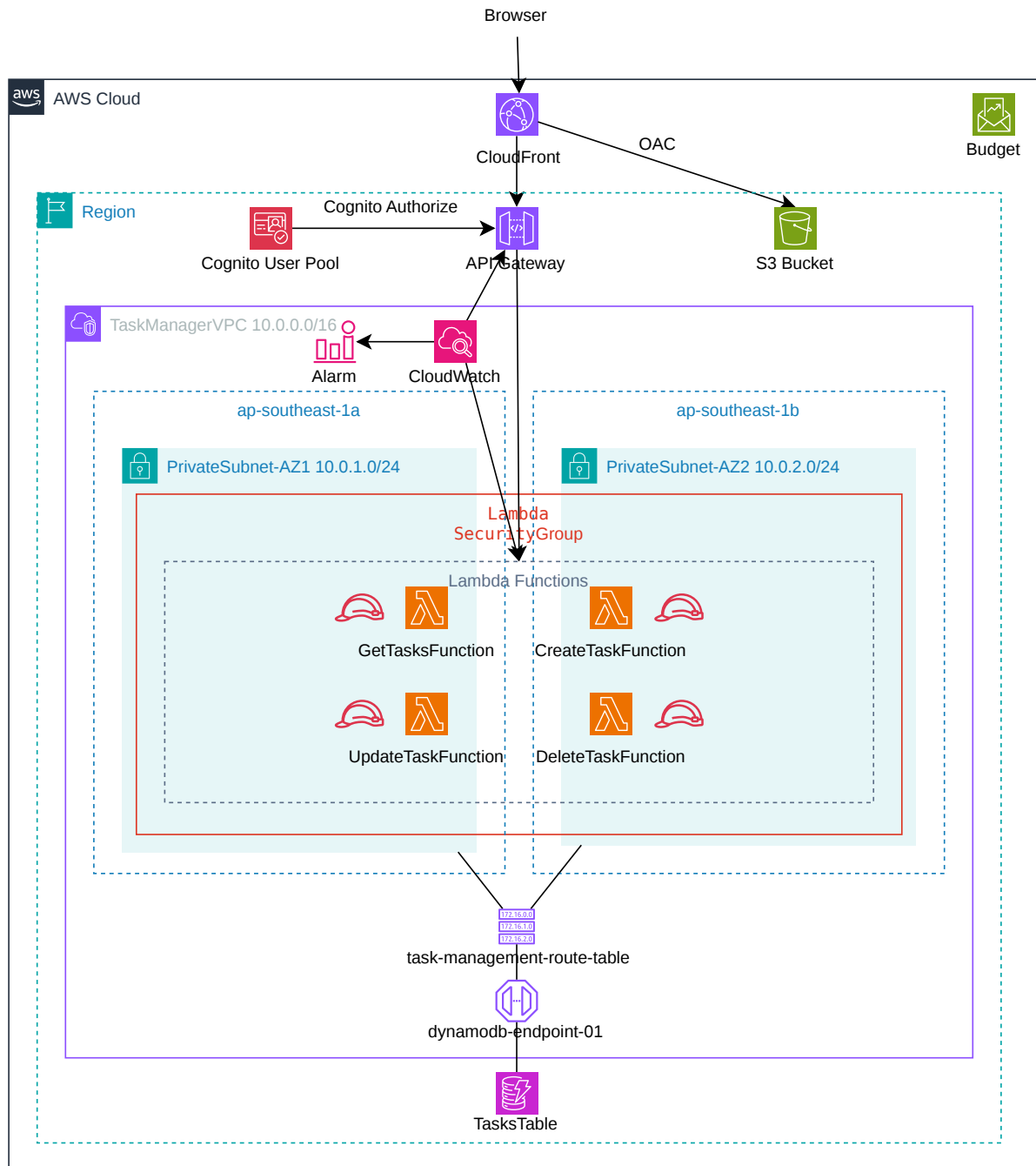
3 Thông tin endpoint

Thông tin	Giá trị
AWS Region	ap-southeast-1
CloudFront URL	https://d1ikfum6io2m2d.cloudfront.net/
API Gateway URL	https://x8hr2ow73f.execute-api.ap-southeast-1.amazonaws.com/prod/
S3 bucket frontend	https://taskmanager-ui-hieunguyen.s3.ap-southeast-1.amazonaws.com/index.html

Bảng 1: Thông tin triển khai thực tế của hệ thống

II Kiến trúc hệ thống

1 Sơ đồ kiến trúc



Hình 1: Sơ đồ kiến trúc serverless của ứng dụng Task Manager

2 Luồng request

Khi người dùng mở ứng dụng, trình duyệt truy cập CloudFront domain. Nếu các file tĩnh như `index.html`, CSS và JavaScript đã có trong cache, CloudFront trả về trực tiếp từ edge location. Nếu cache miss, CloudFront lấy object từ S3 private bucket thông qua OAC. S3 bucket không public nên truy cập trực tiếp đến URL S3 sẽ bị từ chối.

Luồng tạo công việc sau khi người dùng đăng nhập:

1. Người dùng đăng nhập bằng Cognito và nhận Token ID.
2. Frontend gửi request HTTPS đến API Gateway endpoint `/tasks`, kèm header `Authorization`.
3. API Gateway dùng Cognito Authorizer để xác thực JWT token.
4. Nếu token hợp lệ, API Gateway gọi Lambda function tương ứng.
5. Lambda function chạy trong private subnet của `TaskManagerVPC`.
6. Lambda gửi request đến DynamoDB qua route table có destination là DynamoDB prefix list và target là VPC endpoint.
7. DynamoDB ghi hoặc đọc dữ liệu trong `TasksTable`.
8. Lambda trả JSON response về API Gateway, sau đó API Gateway trả kết quả về trình duyệt.

3 Tự mở rộng serverless

Hệ thống không cần Application Load Balancer vì API Gateway đã đóng vai trò entry point HTTPS và định tuyến request đến Lambda. Khi có nhiều request đồng thời, Lambda tự động tạo thêm execution environment để xử lý song song. Khi không có request, Lambda có thể giảm về không instance đang chạy, giúp giảm chi phí vận hành.

Trong phiên bản triển khai hiện tại, nhóm chưa cấu hình reserved concurrency cho các Lambda function. Lý do là hệ thống còn nhỏ, phục vụ mục đích demo và chưa có dữ liệu tải thực tế từ người dùng để xác định ngưỡng concurrency hợp lý. Nếu đặt reserved concurrency dựa trên phỏng đoán, giá trị quá thấp có thể gây throttling không cần thiết, còn giá trị quá cao không tạo thêm lợi ích kiểm soát chi phí so với quy mô hiện tại. Vì vậy, nhóm ưu tiên dùng API Gateway throttling,

CloudWatch monitoring và AWS Budget để kiểm soát lưu lượng, lỗi và chi phí trước. Reserved concurrency sẽ được cấu hình sau khi có baseline về số request, thời gian xử lý và mức concurrency thực tế.

4 CDN và Origin Access Control

CloudFront giúp giảm độ trễ bằng cách cache static assets tại edge location gần người dùng. Khi cache hit, CloudFront trả nội dung mà không cần truy cập lại S3. Khi cache miss, CloudFront lấy nội dung từ origin là S3 bucket.

S3 bucket phải private để người dùng không thể truy cập trực tiếp file bằng URL S3. Nếu S3 public, người dùng có thể bypass CloudFront, làm mất các kiểm soát như HTTPS, caching và policy truy cập qua CDN.

OAC cho phép CloudFront đọc file từ S3 private bucket một cách an toàn. Bucket policy chỉ cho phép CloudFront distribution hợp lệ truy cập object. Vì vậy, người dùng phải đi qua CloudFront để mở frontend, còn truy cập trực tiếp S3 sẽ bị từ chối với **403 Forbidden** hoặc **AccessDenied**.

5 VPC Endpoint

Lambda được gắn VpcConfig vào hai private subnet để backend chạy trong mạng riêng. Vì private subnet không có NAT Gateway, Lambda không thể gọi DynamoDB qua internet công cộng. DynamoDB Gateway Endpoint giải quyết vấn đề này bằng cách thêm route đến DynamoDB prefix list trong route table của private subnet.

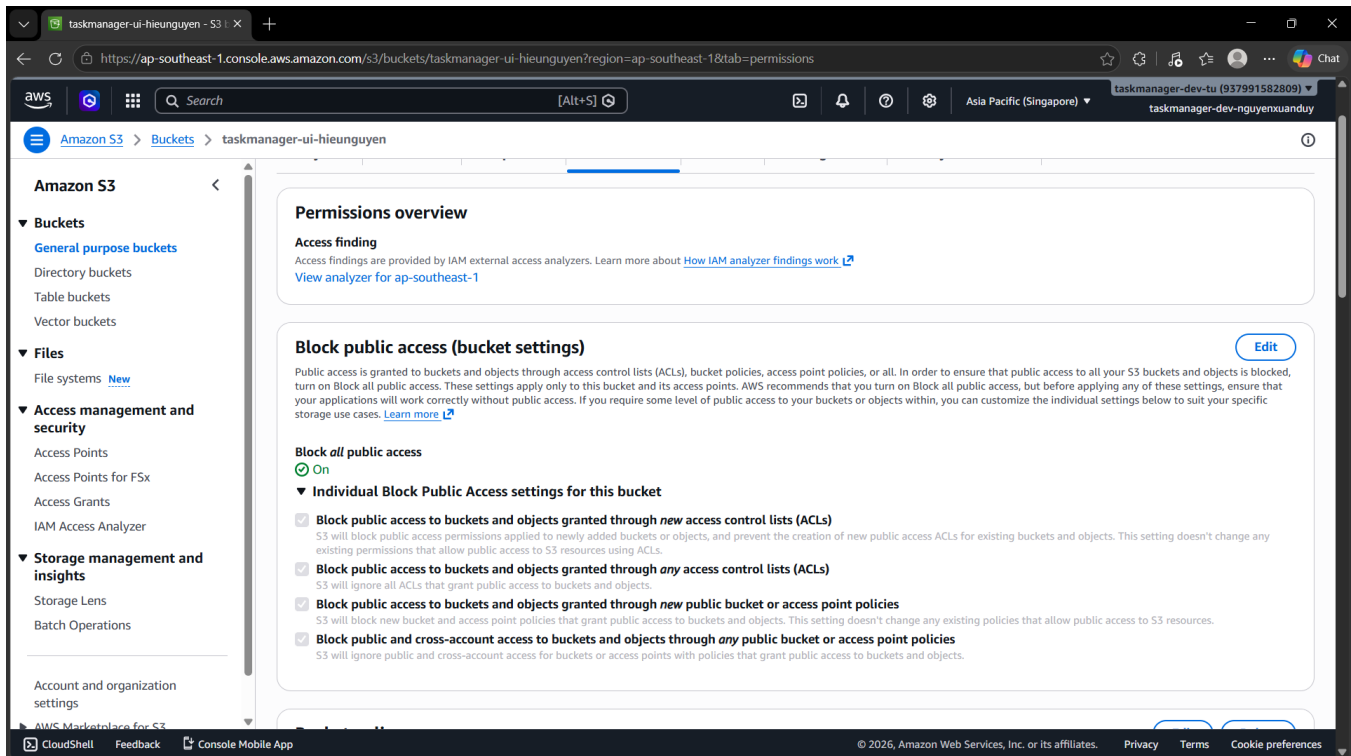
Traffic từ Lambda đến DynamoDB đi qua AWS private backbone theo đường: Lambda trong private subnet → route table → DynamoDB Gateway Endpoint → DynamoDB. Cách này chi phí cố định như NAT Gateway.

III Kết quả và bằng chứng

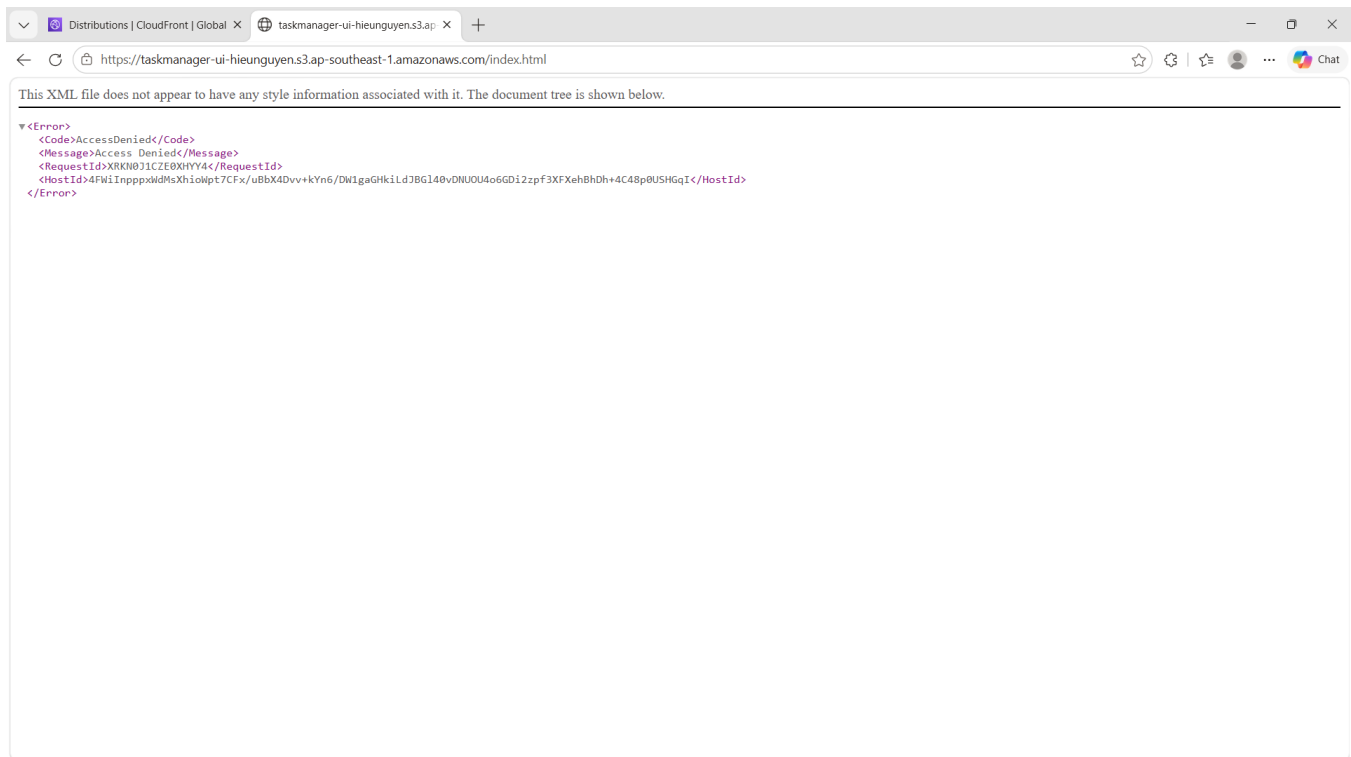
1 Bằng chứng bảo mật frontend

ID	Bằng chứng
SE-1	S3 Block Public Access bật cả bốn tùy chọn.
SE-2	Truy cập trực tiếp S3 URL trả về 403 Forbidden hoặc AccessDenied.
SE-3	Truy cập CloudFront URL thành công với 200 OK.
SE-4	CloudFront distribution có Origin Access Control.

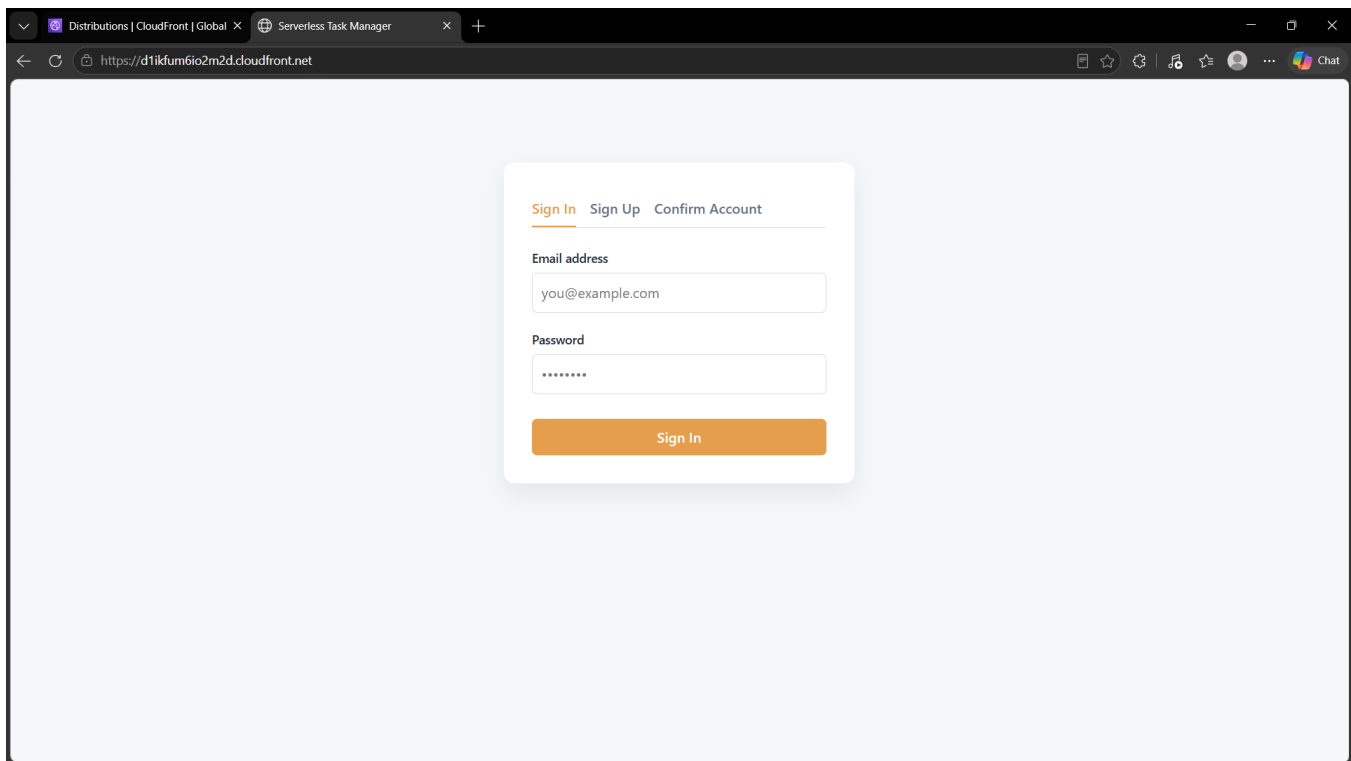
Bảng 2: Bằng chứng bảo mật frontend



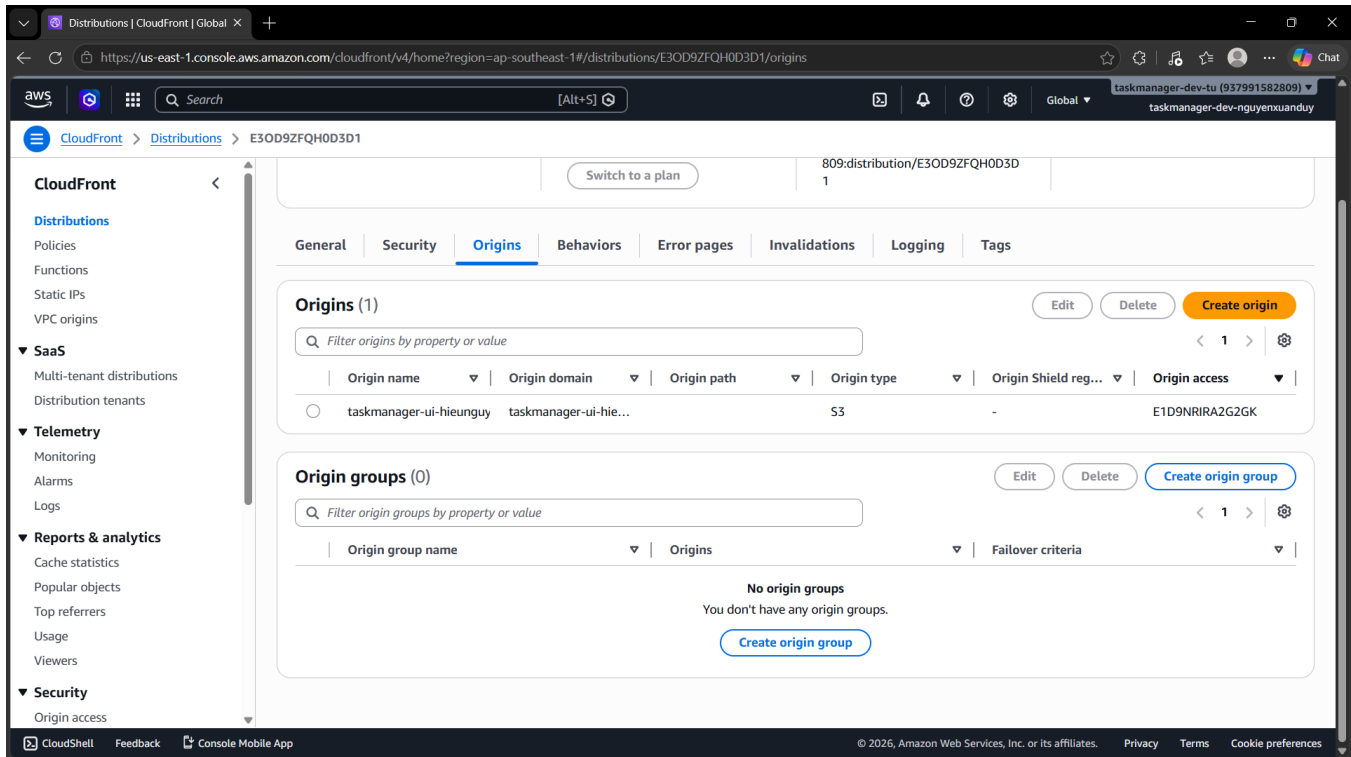
Hình 2: Ảnh/ouput bằng chứng SE1



Hình 3: Ảnh/ouput bằng chứng SE2



Hình 4: Ảnh/ouput bằng chứng SE3

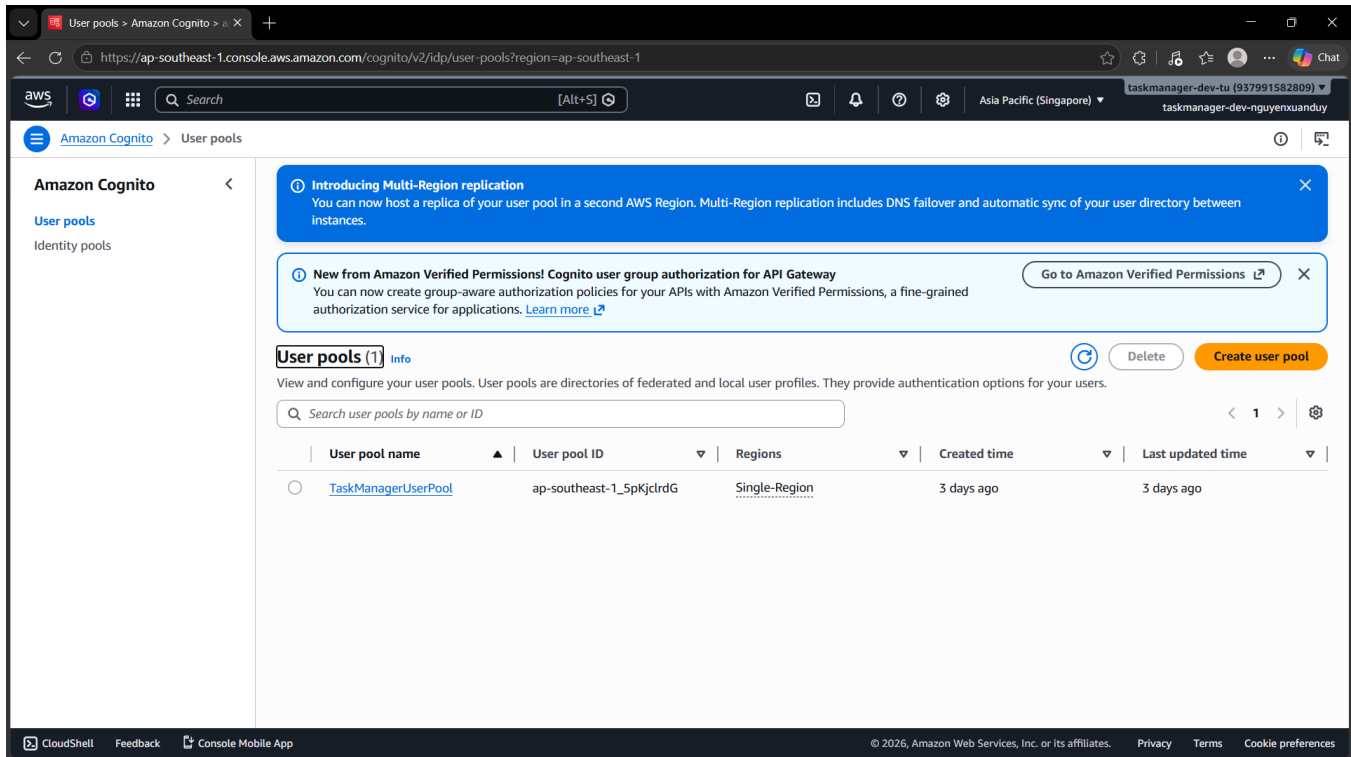


Hình 5: Ảnh/ouput bằng chứng SE4

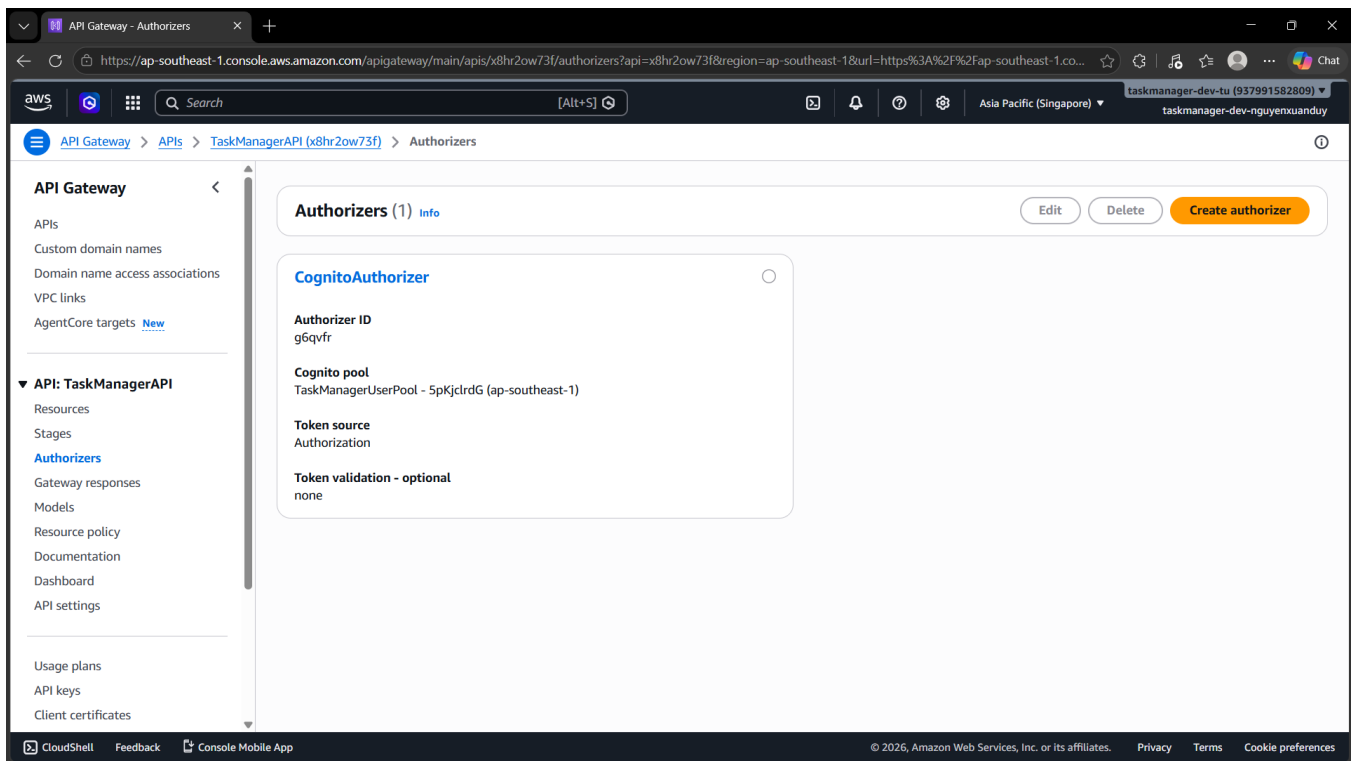
2 Bằng chứng Cognito và API security

ID	Bằng chứng
CO-1	Cognito User Pool TaskManagerUserPool đã tạo.
CO-2	API Gateway Cognito Authorizer đã cấu hình.
CO-3	Gọi API không có token trả về 401 Unauthorized.
CO-4	Gọi API với token hợp lệ trả về 200 OK.

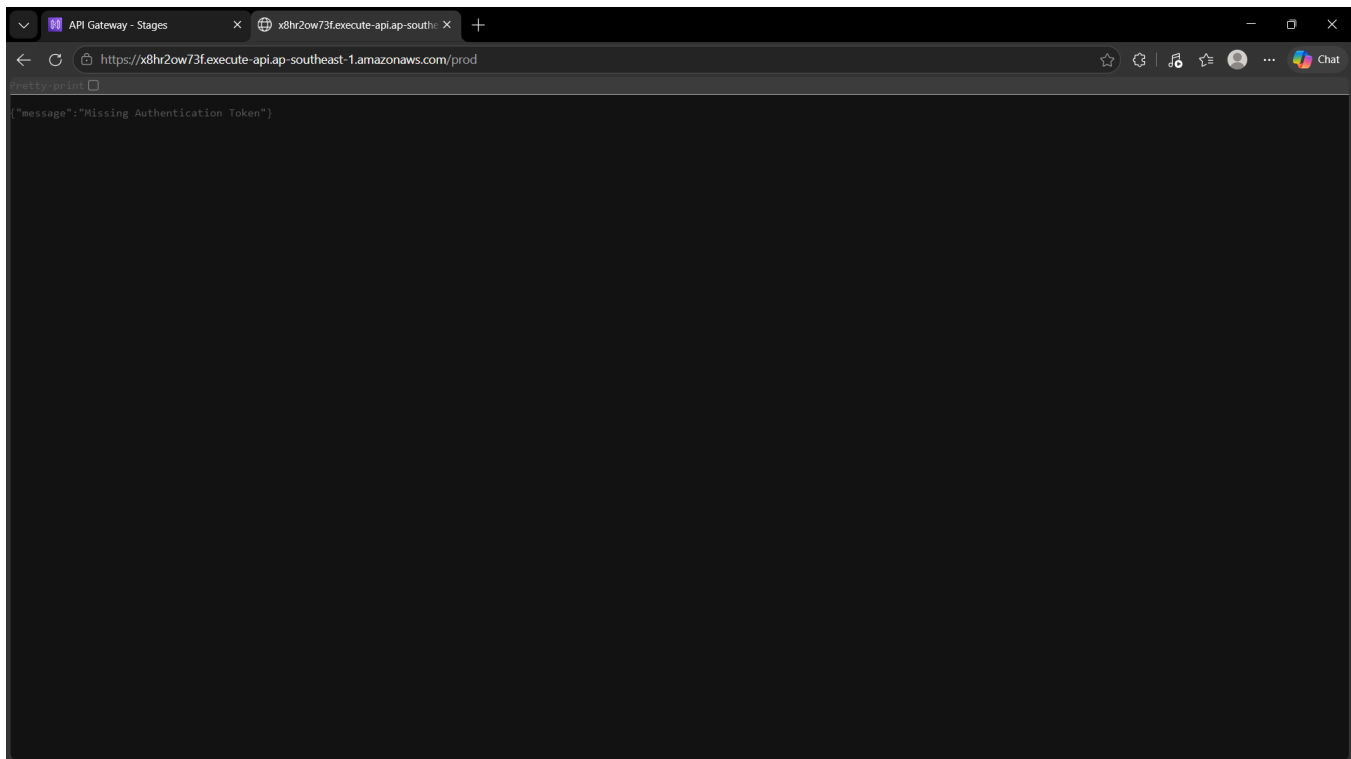
Bảng 3: Bằng chứng Cognito và API security



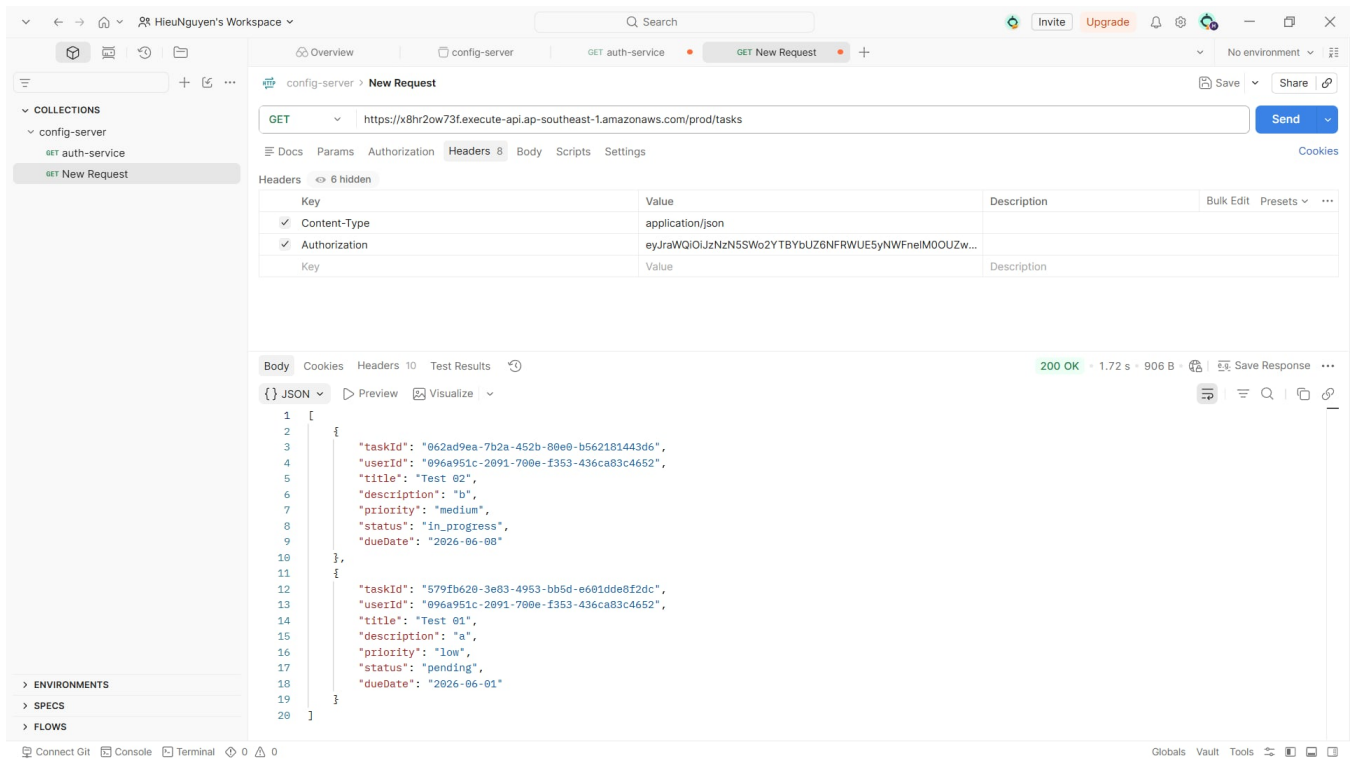
Hình 6: Ảnh/ouput bằng chứng CO1



Hình 7: Ảnh/ouput bằng chứng CO2



Hình 8: Ảnh/ouput bằng chứng CO3

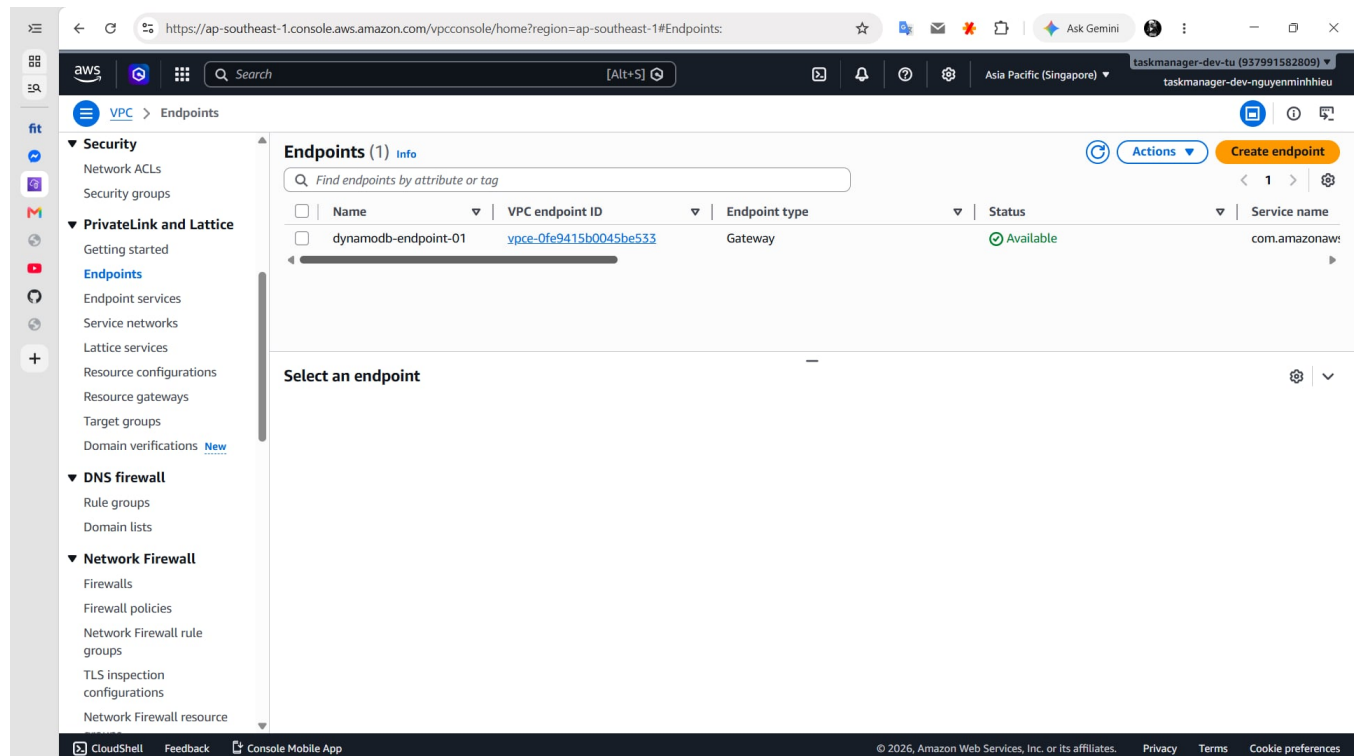


Hình 9: Ảnh/ouput bằng chứng CO4

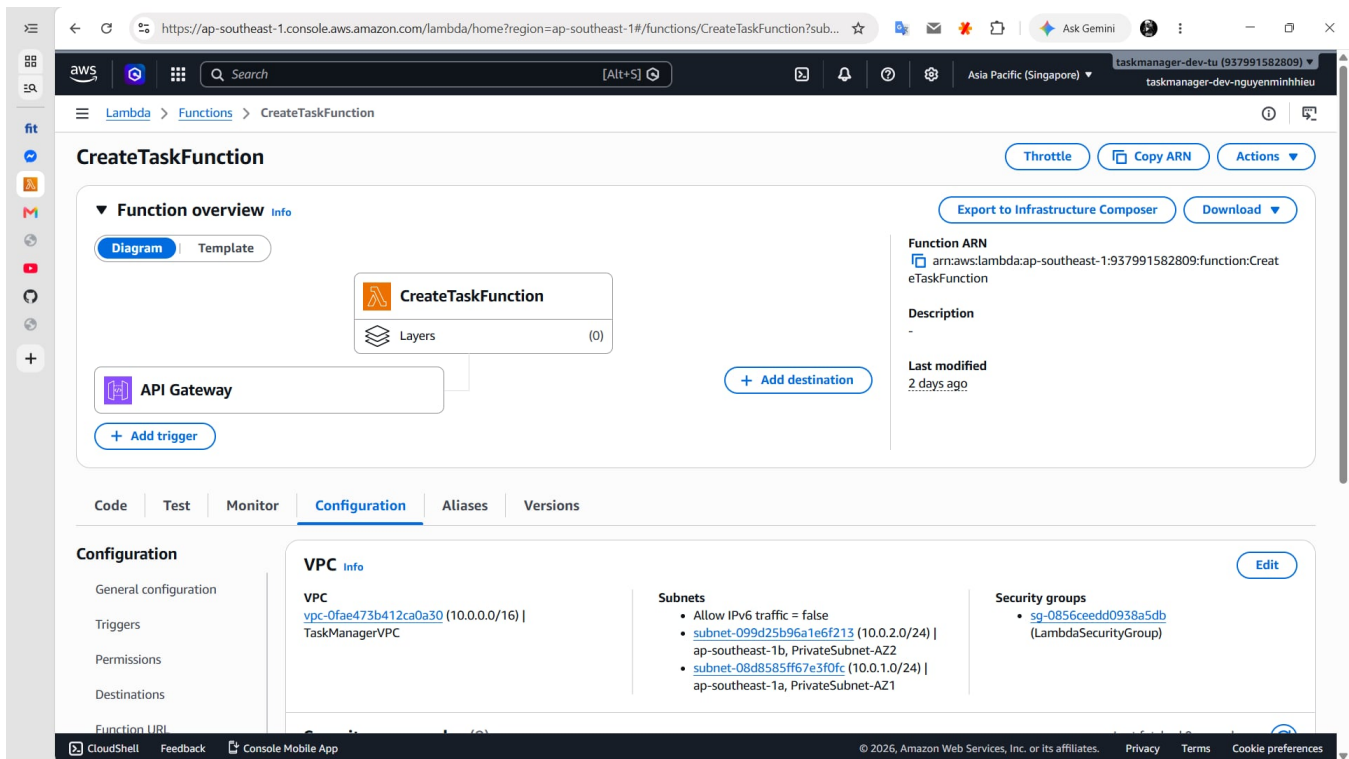
3 Bằng chứng networking

ID	Bằng chứng
NE-1	DynamoDB Gateway Endpoint có status Available .
NE-2	Lambda có VpcConfig với private subnets và security group.
NE-3	Route table có dòng pl-xxxxxx -> vpce-xxxxxxx .
NE-4	Không có NAT Gateway đang hoạt động.
NE-5	CloudWatch log cho thấy Lambda gọi DynamoDB thành công.

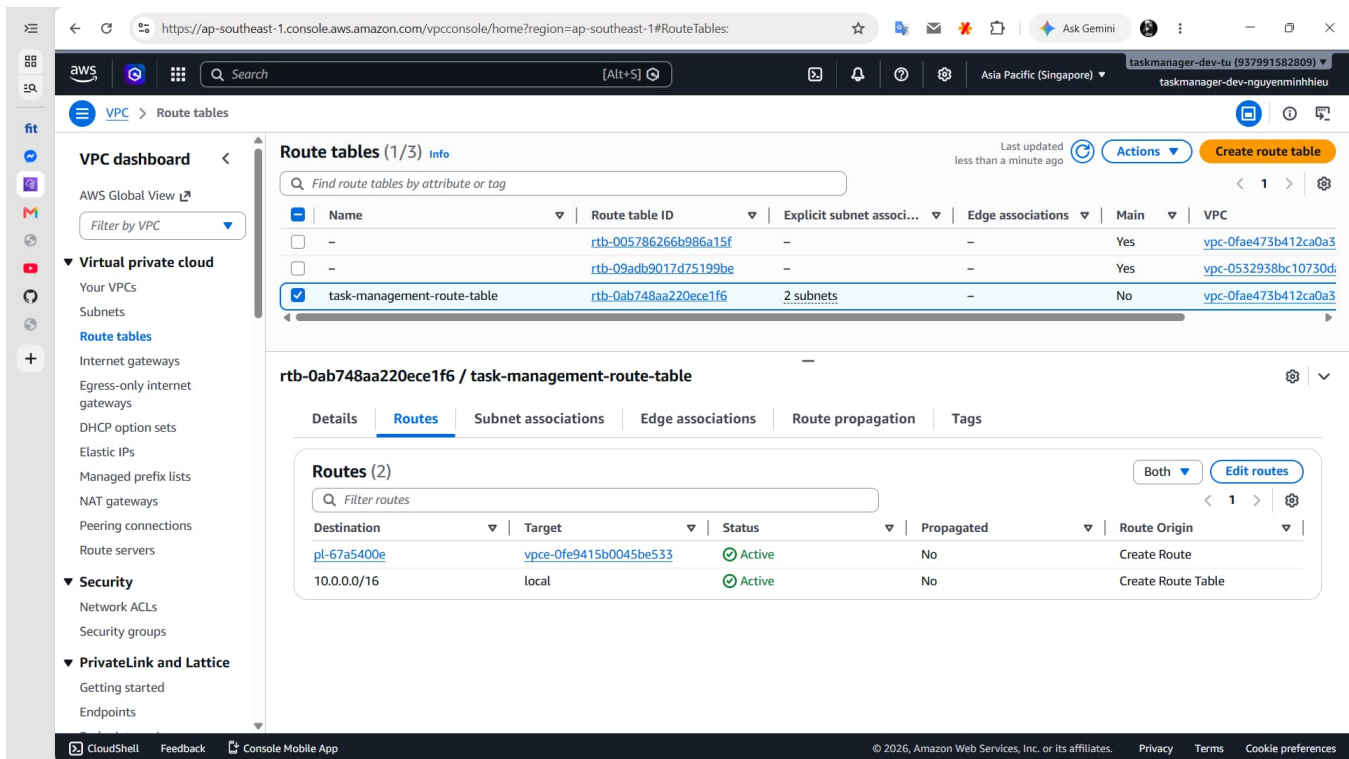
Bảng 4: Bằng chứng networking



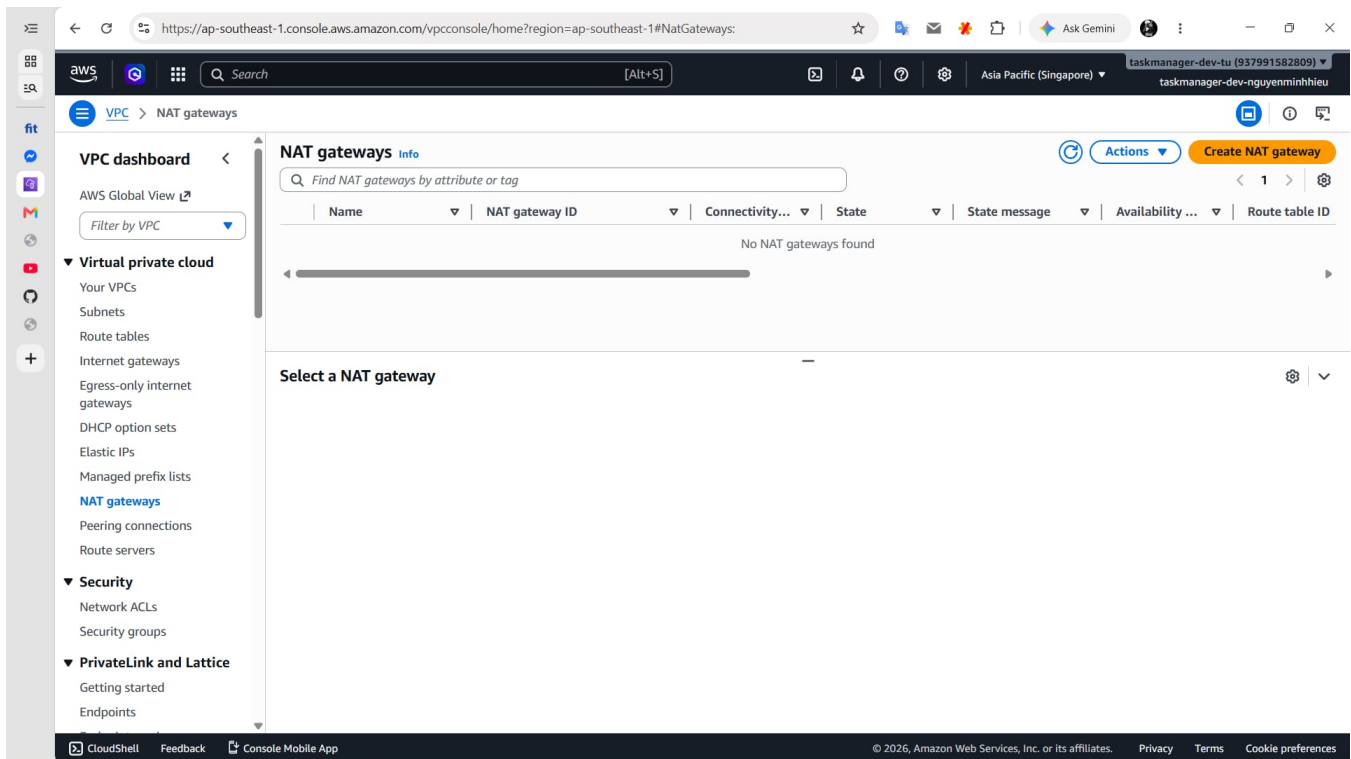
Hình 10: Ảnh/ouput bằng chứng NE1



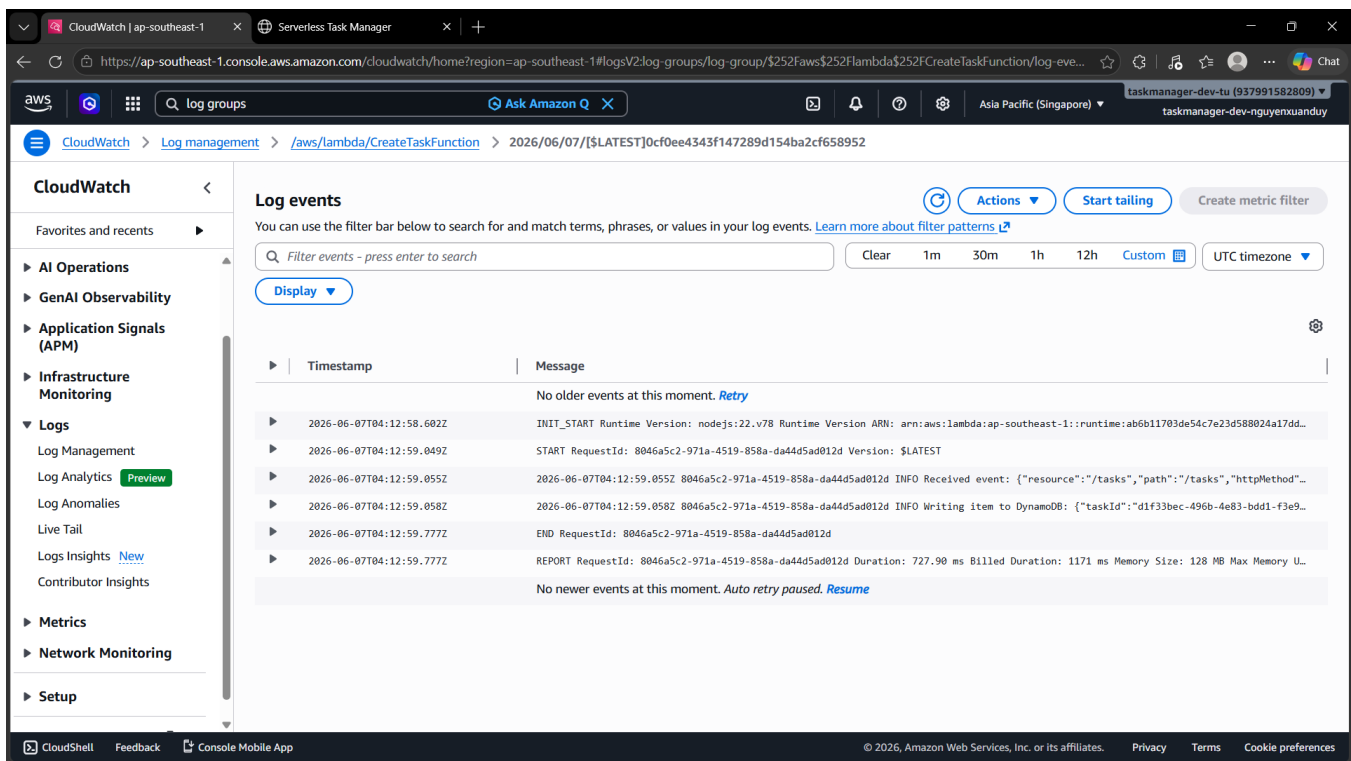
Hình 11: Ảnh/ouput bằng chứng NE2



Hình 12: Ảnh/ouput bằng chứng NE3



Hình 13: Ảnh/ouput bằng chứng NE4

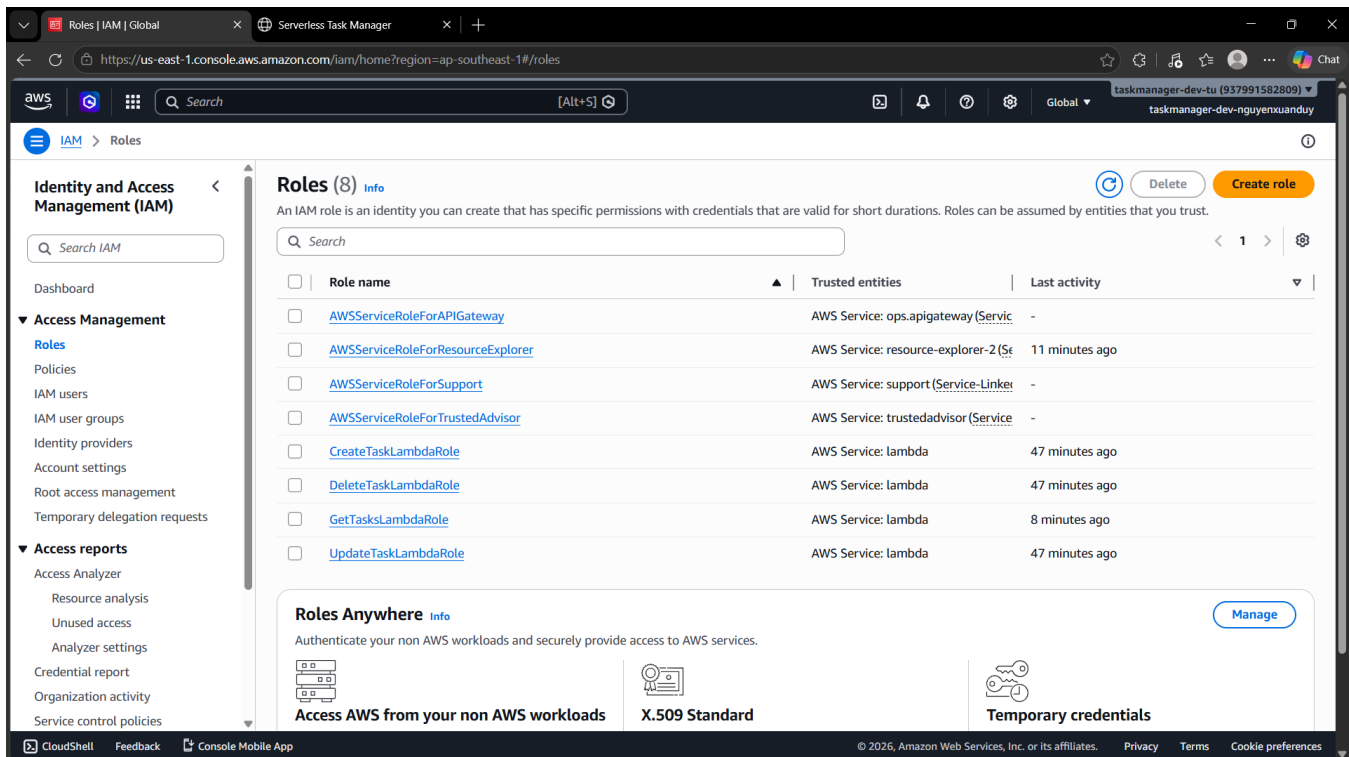


Hình 14: Ảnh/ouput bằng chứng NE5

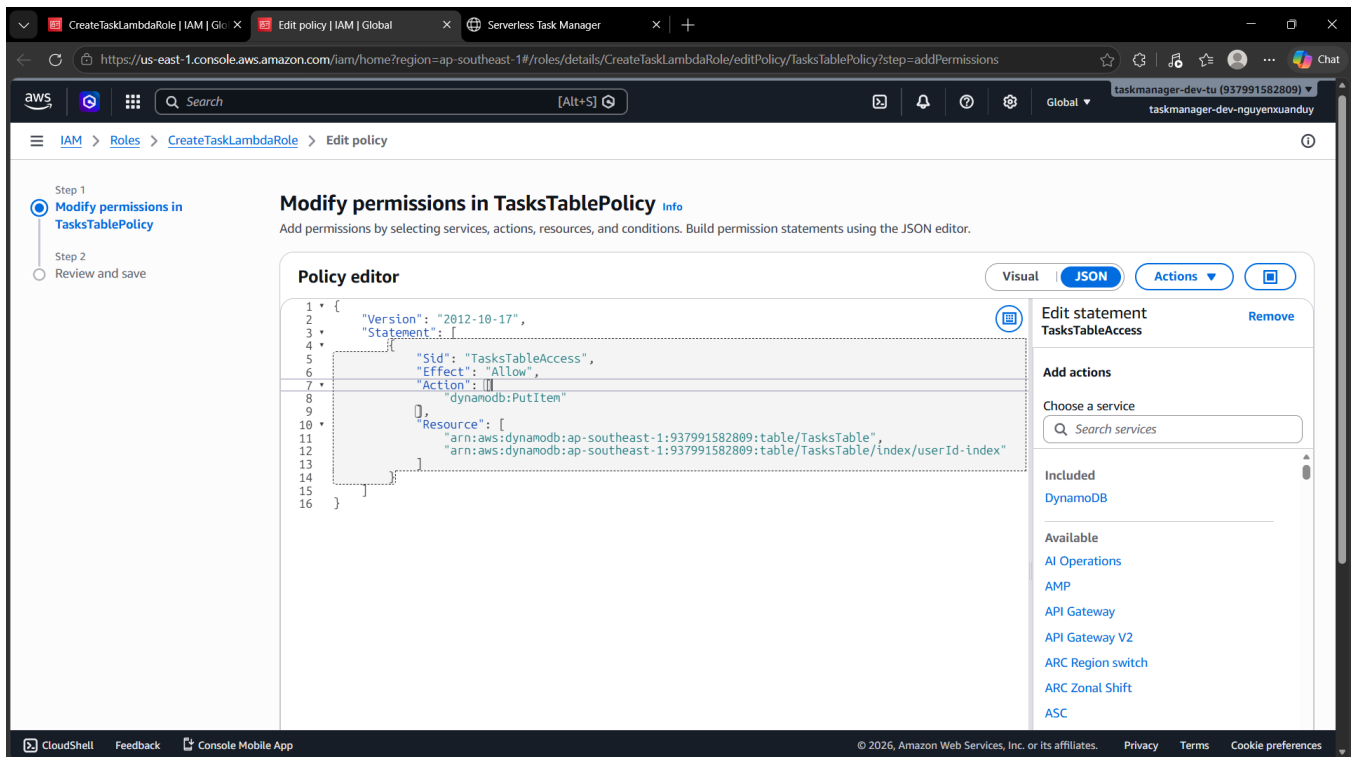
4 Bằng chứng IAM

ID	Bằng chứng
IM-1	Bốn IAM role riêng: <code>GetTasksLambdaRole</code> , <code>CreateTaskLambdaRole</code> , <code>UpdateTaskLambdaRole</code> , <code>DeleteTaskLambdaRole</code> .
IM-2	Policy JSON dùng ARN cụ thể của <code>TasksTable</code> và <code>userId-index</code> , không dùng resource <code>*</code> .
IM-3	Mỗi Lambda function gắn đúng IAM role tương ứng.

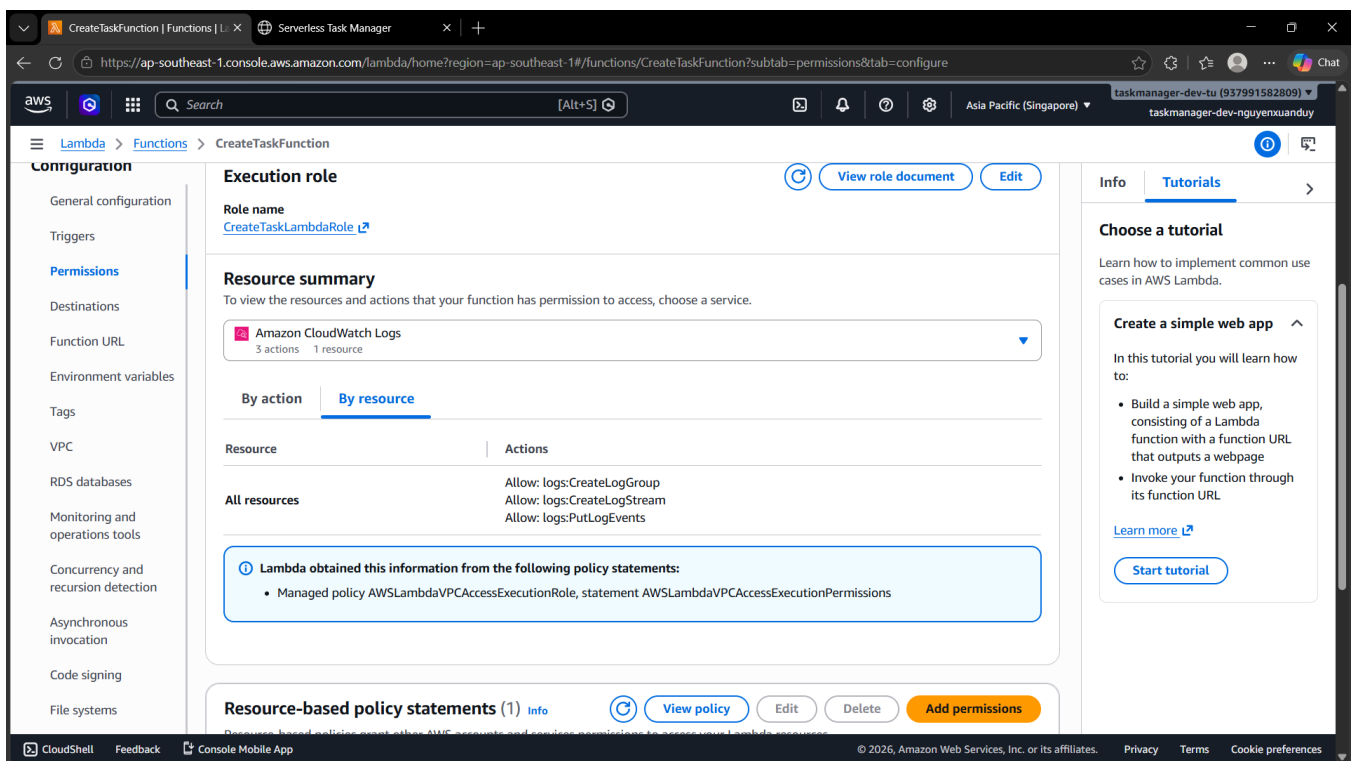
Bảng 5: Bằng chứng IAM



Hình 15: Ảnh/ouput bằng chứng IM1

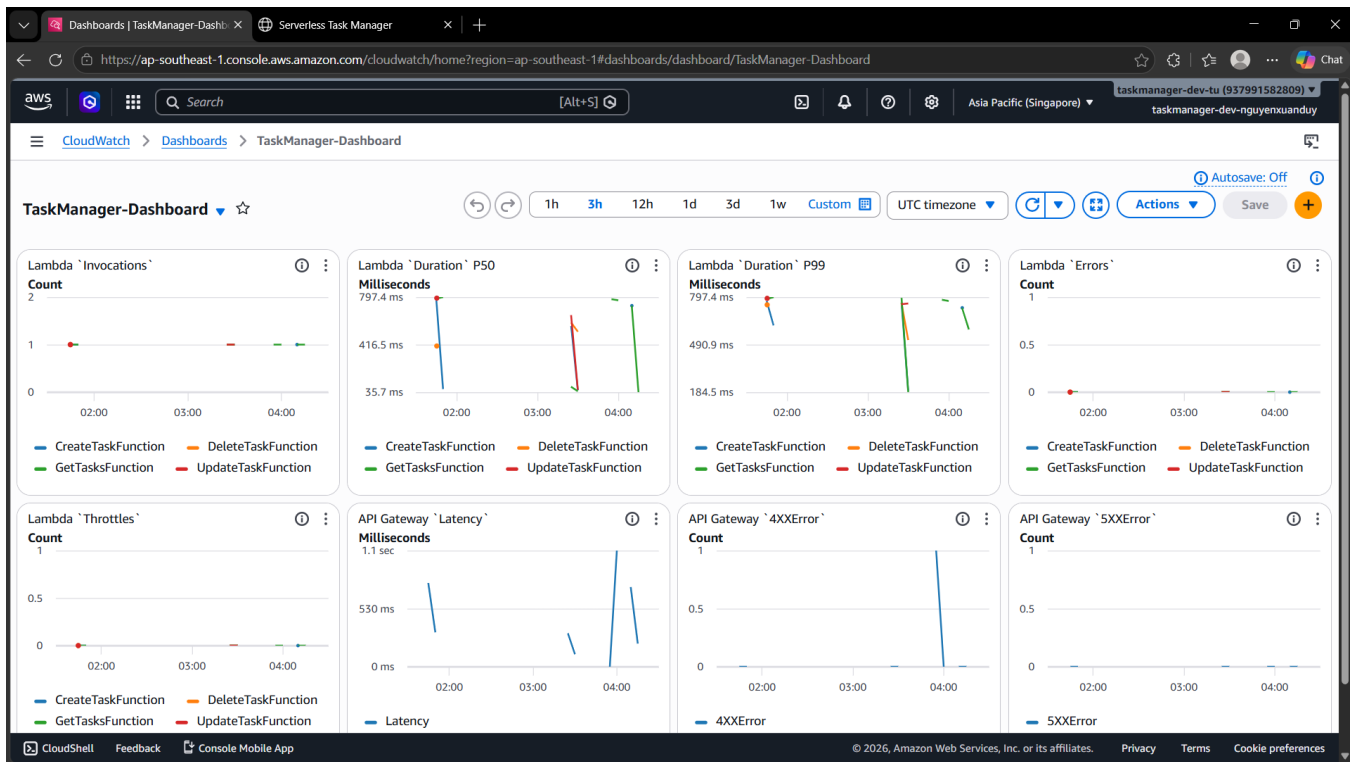


Hình 16: Ảnh/ouput bằng chứng IM2

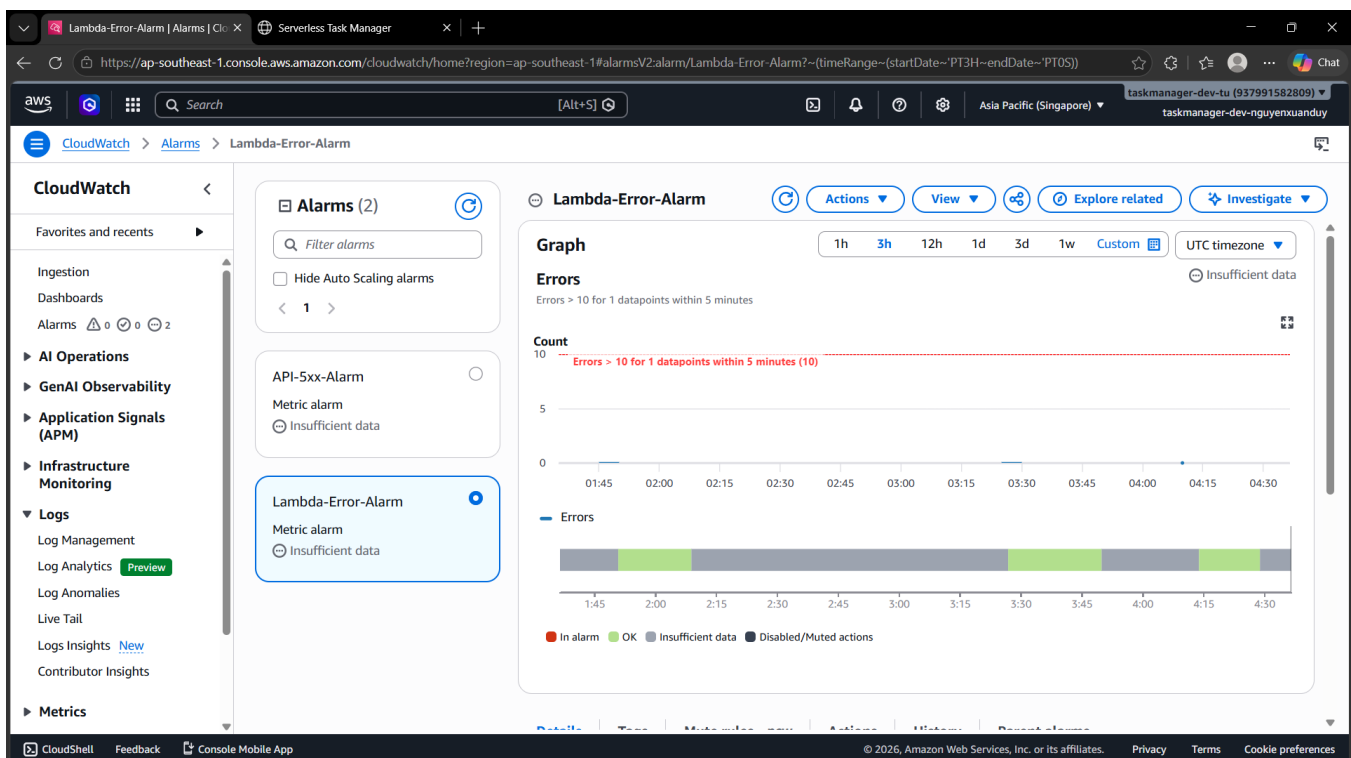


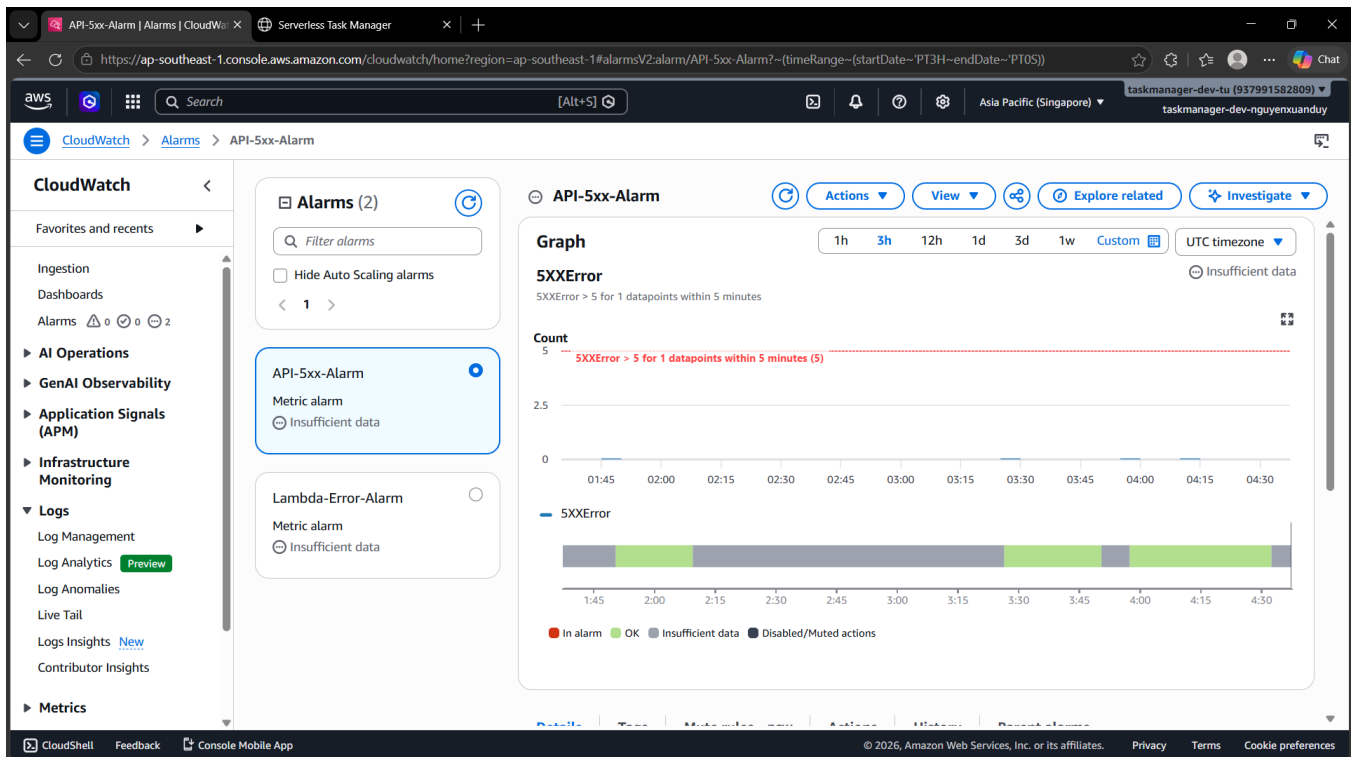
Hình 17: Ảnh/ouput bằng chứng IM3

5 Giám sát

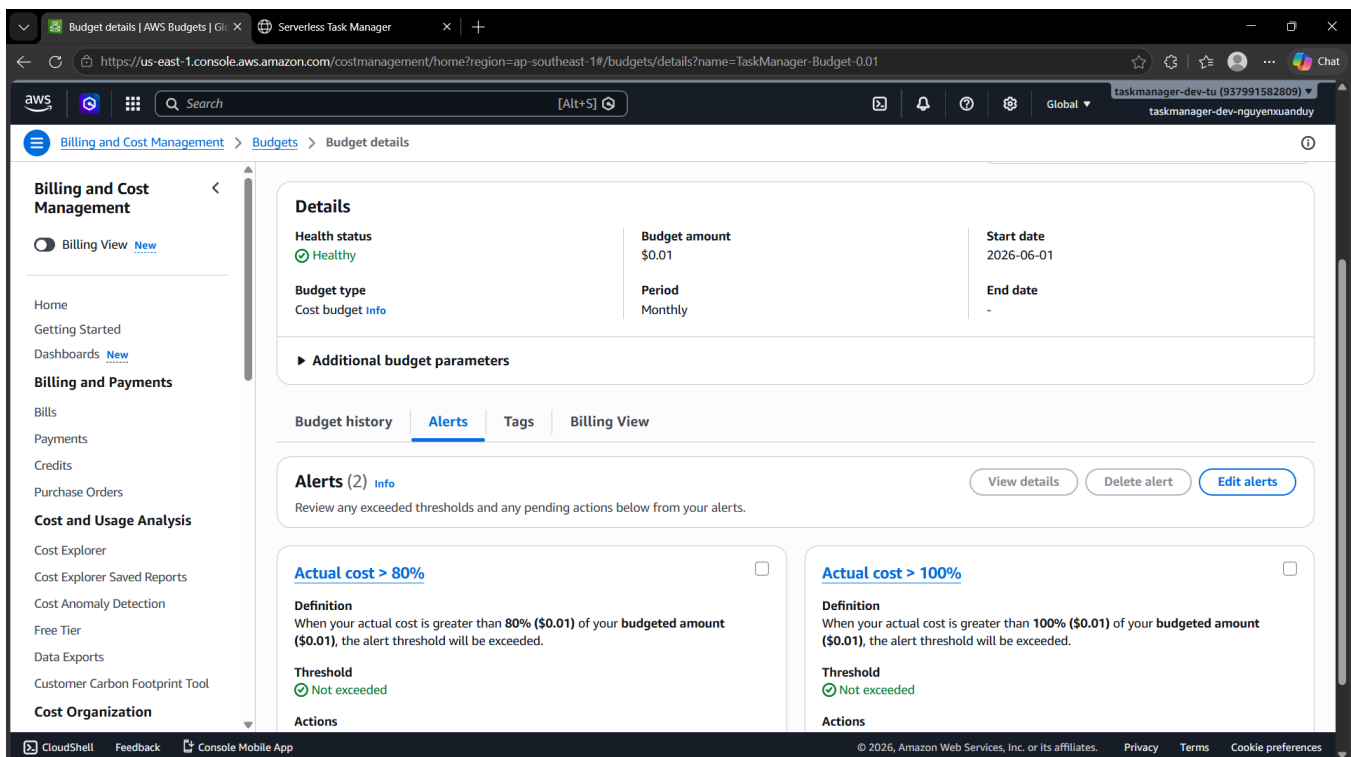


Hình 18: CloudWatch Dashboard cho thấy ít nhất 5 widget với dữ liệu thực





Hình 19: Hai CloudWatch alarm đã được tạo



Hình 20: Trang cấu hình budget

6 Chi phí

IV Đánh giá

1 Bảng đánh giá

Hạng mục	Tỷ trọng	Yêu cầu điểm tối đa	Điểm đánh giá
Chức năng	20%	Bốn thao tác CRUD hoạt động đúng. Frontend, backend và DynamoDB tích hợp chính xác. Bộ lọc theo độ ưu tiên và ngày hết hạn hoạt động.	20 / 20
Triển khai Đám mây	25%	S3 private và CloudFront OAC được xác minh. Lambda trong VPC có DynamoDB Endpoint. IAM least privilege với role riêng. Cognito xác thực đúng. CORS chỉ cho phép CloudFront domain.	25 / 25
Hiểu biết Kiến trúc	20%	Giải thích được luồng request, VPC Endpoint, lý do thay thế NAT Gateway, Lambda auto-scaling, API Gateway load balancing, CloudFront caching và OAC.	20 / 20
Giám sát	10%	CloudWatch Dashboard có ít nhất 5 widget với dữ liệu thực. Hai alarm được tạo. Có log request thành công, log request lỗi và SNS email notification.	10 / 10
Hiệu quả Chi phí	15%	Không có NAT Gateway. API Gateway throttling, CloudWatch monitoring và AWS Budget 0.01 USD được cấu hình để kiểm soát chi phí. Reserved concurrency chưa được đặt do chưa có baseline tải thực tế. Tổng chi phí bằng 0 hoặc gần 0.	15 / 15
Tài liệu	10%	Báo cáo giải thích đủ bốn khái niệm chính, sơ đồ kiến trúc đủ thành phần, đủ 16 mục bằng chứng SE/NE/IM/CO, có prompt GenAI nếu sử dụng, và nộp source code.	10 / 10

Bảng 6: Bảng đánh giá theo rubric của đồ án

2 Phân chia công việc

Thành viên	MSSV	Công việc chính	Đóng góp
Nguyễn Minh Tú	23120101	Triển khai bốn Lambda Function cho các thao tác CRUD, cấu hình runtime Node.js 20.x. Thiết lập Cognito User Pool, App Client.	33.3%
Nguyễn Xuân Duy	23120121	Thiết kế và tạo bảng DynamoDB TasksTable , GSI userId-index và dữ liệu demo. Cấu hình IAM Least Privilege cho Lambda roles. Thiết lập CloudWatch Dashboard, CloudWatch Alarms, SNS notification, AWS Budget và các kiểm soát chi phí.	33.3%
Nguyễn Minh Hiếu	23120124	Thiết lập networking gồm custom VPC, private subnets, route table, security group và DynamoDB Gateway Endpoint. Cấu hình API Gateway REST API, Cognito Authorizer, stage prod , CORS. Triển khai S3 private bucket, CloudFront distribution và OAC cho frontend.	33.3%

Bảng 7: Bảng phân chia công việc nhóm

A Phụ lục

1. Codex. GPT-5.5. OpenAI, truy cập ngày 28 tháng 5 năm 2026, prompt: “*Read the PROJECT2_VI.pdf create a step-by-step instruction that follows the requirements in that pdf file. Ask me a series of yes/no questions that helps you improve your accuracy.*”; được sử dụng để tạo file hướng dẫn triển khai AWS theo từng bước dựa trên yêu cầu của PROJECT2_VI.pdf; AI tổng hợp các bước cấu hình chính như networking, DynamoDB, IAM, Lambda, Cognito, API Gateway, S3/CloudFront, monitoring và cost control, nhóm rà soát lại để đảm bảo hướng dẫn phù hợp với cách triển khai thủ công bằng AWS Console.
2. Codex. GPT-5.5. OpenAI, truy cập ngày 28 tháng 5 năm 2026, prompt: “*add objective and result for each step in the instruction file*”; được sử dụng để bổ sung mục tiêu và kết quả mong đợi cho từng bước trong file hướng dẫn triển khai; AI giúp làm rõ lý do thực hiện từng bước và trạng thái cần đạt được sau bước đó.
3. Codex. GPT-5.5. OpenAI, truy cập ngày 5 tháng 6 năm 2026, prompt: “*Design a RESTful backend for a Task Manager using AWS Lambda and DynamoDB?*”; được sử dụng để thiết kế backend RESTful cho ứng dụng Task Manager, bao gồm các endpoint CRUD, cấu trúc Lambda handler, cách đọc/ghi DynamoDB và định dạng JSON response; nhóm điều chỉnh lại thiết kế để phù hợp với yêu cầu bốn Lambda function riêng biệt trong đồ án.
4. Codex. GPT-5.5. OpenAI, truy cập ngày 6 tháng 6 năm 2026, prompt: “*Implement frontend for this application.*”; được sử dụng để xây dựng frontend cho ứng dụng quản lý công việc; nhóm chỉnh sửa lại cấu hình API/Cognito theo deployment thực tế.
5. Codex. GPT-5.5. OpenAI, truy cập ngày 6 tháng 6 năm 2026, prompt: “*I am getting errors when calling my Lambda API from my S3-hosted frontend using API Gateway. How to fix this?*”; được sử dụng để hỗ trợ phân tích lỗi khi frontend gọi API Gateway, các vấn đề gặp phải là CORS, sai invoke URL; nhóm áp dụng các gợi ý phù hợp để kiểm tra lại cấu hình API Gateway và frontend.
6. Codex. GPT-5.5. OpenAI, truy cập ngày 7 tháng 6 năm 2026, prompt: “*Read the PROJECT2_VI.pdf to understand the project. I already done with the aws deployment. I need to write a report follow the requirements in the PROJECT2_VI.pdf. Ignore the current latex content. Create*”

an outline for the report. You can ask me a series of yes/no question to help you with your writing.”; được sử dụng để phân tích yêu cầu trong file PROJECT2_VI.pdf, xác định các mục bắt buộc của báo cáo như kiến trúc, bảo mật, networking, IAM, Cognito, monitoring, cost control và evidence checklist; AI đề xuất dàn ý ban đầu, nhóm điều chỉnh lại theo triển khai AWS thực tế và các bằng chứng đã thu thập.

7. Codex. GPT-5.5. OpenAI, truy cập ngày 7 tháng 6 năm 2026, prompt: *“Why should I use Amazon CloudFront in front of an S3 bucket instead of accessing S3 directly?”*; được sử dụng để hiểu rõ lý do đặt CloudFront trước S3, bao gồm CDN caching, HTTPS, OAC, private S3 bucket và việc ngăn người dùng truy cập trực tiếp S3; nhóm dùng nội dung này để giải thích phần CDN/OAC trong báo cáo.
8. Codex. GPT-5.5. OpenAI, truy cập ngày 7 tháng 6 năm 2026, prompt: *“Explain the trade-offs of Reserved Concurrency in AWS Lambda and what happens when the account concurrency limit is reached?”*; được sử dụng để tìm hiểu ưu/nhược điểm của reserved concurrency, ảnh hưởng khi đặt quá thấp hoặc quá cao, và hành vi throttling khi đạt giới hạn concurrency của tài khoản; nhóm dùng nội dung này để viết phần giải thích vì sao chưa cấu hình reserved concurrency khi chưa có baseline tải thực tế.